

SECURITY REPORT

Automated validation results + findings register. Every check states whether it blocks deployment. Full model: [SECURITY.md](#).

Scanner matrix (executed)

Check	Tool / where	Result
Secret detection	gitleaks (explicit paths, no config)	clean
Deps HIGH/CRITICAL	trivy fs, exact pins	0
Dockerfile misconfig	trivy misconfig	0
laC misconfig	trivy misconfig (6 fixed, 4 suppressed w/ reason)	0
laC policy	Checkov (CI; host-blocked, evidenced)	CI
Deps audit	pip-audit, all 6 files	0 (after fix)
Image scan	trivy image, api+worker (CI)	CI (daemon-bound)
Lint/security-adjacent	ruff E/F/I/UP/W	clean

Finding M9-1 — deliberate leak blocks pipeline (SEV critical, EXECUTED)

- Affected: pipeline gate (`ci.sh --demo-block` plants untracked dummy).
- Evidence: `ci-plant-3378.tmp:generic-api-key:1`, exit 1, PIPELINE BLOCKED.
- Remediation: trap removal → clean run exit 0 (PASS=7/8).
- Blocks deployment: YES (exit≠0 stops everything downstream).

Finding D30 — 18 vulnerable deps (SEV high, EXECUTED)

- Affected: `requests==2.32.3`, transitive `starlette 0.41.3` (via fastapi).
- Evidence: pip-audit 18 findings → bumps (`requests 2.33.0`, `fastapi 0.135.0`, `starlette 1.6.0`) → 48/48 tests green → pip-audit 0, trivy still 0.
- Blocks deployment: YES (pip-audit gate in `ci.sh` + CI depsec job).

Finding D24 — 10 laC misconfigs triaged (SEV mixed, EXECUTED)

- 6 fixed (HTTPS/TLS13, immutable ECR, flow logs, IAM auth, restricted egress, SG cycle), 4 suppressed with in-code justification.
- Re-scan: ZERO. Blocks deployment: YES (trivy + Checkov gates).